

Information Security Statement

The technical and organisational measures protecting student and school data.

Last reviewed 2026-05-24

WHAT WE HOLD AND WHAT WE DON'T

We are honest about certification status. We are **not** yet ISO/IEC 27001 certified (on roadmap, targeted late 2026) and we do **not** hold Cyber Essentials Plus or the NCSA NIA certification. The measures below are real and in force; the formal certifications that independently attest to them are a separate, in-progress workstream. We say so plainly so your security team knows exactly what they are buying.

Data in transit and at rest

- **In transit:** TLS 1.3 across all connections.
- **At rest:** AES-256 encryption in the primary database and object storage.
- **Passwords:** hashed with Argon2id (memory-hard); never stored or logged in plaintext.

Access control

- Row-level security in the database scopes every record to its owning user / school.
- Least-privilege staff access via SSO with multi-factor authentication; access reviewed quarterly.

- Multi-factor authentication available to all users; SSO (Google Workspace / Microsoft 365) supported for annual school deployments.
- Administrative actions are written to an append-only audit log.

Application security

- Per-request Content-Security-Policy with a fresh nonce; HSTS; X-Frame-Options DENY; X-Content-Type-Options nosniff; strict Referrer-Policy; Cross-Origin-Opener-Policy and Cross-Origin-Resource-Policy set to same-origin.
- Rate limiting on authentication and sensitive endpoints (via Upstash Redis in the serverless runtime).
- Account-enumeration defences on signup and login.
- Cloudflare WAF + protective network layer at the edge.
- Session tokens are high-entropy, rotated, and expire.

AI boundary controls

- Essay text is sent to the AI sub-processor under **opaque identifiers** — no name, email, date of birth or school crosses the AI boundary.
- Outbound payloads are minimised to the essay free-text, the question, and the exam board + year.
- API keys are scoped and rotatable; every AI request is logged for audit.
- Contractual position: no training on submissions (counter-signed AI DPA + written zero-retention confirmation being finalised with counsel — see Document 03).

Monitoring and resilience

- Error and performance monitoring via Sentry with PII scrubbed from payloads before send.
- Managed database with point-in-time recovery; object storage redundancy at the provider level.

- Infrastructure hosted on Supabase (EU primary database), Microsoft Azure UK South (backend), and Vercel (front end) — all enterprise-grade providers with their own SOC 2 / ISO posture.

Organisational measures

- Data Protection Officer appointed (Calum Johnson, dpo@theenglishhub.app).
- Designated Safeguarding Lead appointed separately (Lauren Johnson, safeguarding@theenglishhub.app).
- Records of Processing Activities maintained (UK GDPR Article 30).
- Three Data Protection Impact Assessments on file (children's data, AI features, analytics).
- Documented breach-response runbook with a 72-hour notification target.
- Sub-processor register reviewed quarterly and on any material change.

Breach response

On becoming aware of a personal data breach affecting a school's data, we notify the school without undue delay and within **72 hours**, with the information needed for the school's own notifications to the ICO and (for Qatar-resident data) the NCGAA. The full runbook and a pre-filled NCGAA notification template are held internally and available to your DPO on request.

Certification roadmap (honest status)

ITEM	STATUS
ICO registration (UK)	Held — ZC016690, verifiable on the ICO public register
UK GDPR / DPA 2018 compliance posture	In force — RoPA, DPIAs, DPO appointed
ICO Children's Code high-privacy defaults	In force — enforced in code, strict test coverage
ISO/IEC 27001	Not certified — targeted late 2026
Cyber Essentials / Cyber Essentials Plus	Baseline in preparation — not yet certified
NCSA NIA certification (Qatar)	Not pursued — deferred until commercially warranted